

HASHIDS, ID雜湊編碼機制(ID Hashing)

在 core 的 [utils.py](#) 整合了Hashids, 將資料庫的ID (如 1, 2) 轉換成看似隨機的雜湊字串 (如 XyZ1aB), 防範惡意爬蟲 / 隱藏業務機密

```
core > utils.py > ...
1  from django.conf import settings
2  from hashids import Hashids
3
4  hashids = Hashids(salt=settings.HASHIDS_SALT, min_length=settings.HASHIDS_MIN_LENGTH)
5
6  def encode_id(raw_id):
7      if not raw_id:
8          return None
9      return hashids.encode(raw_id)
10
11 def decode_id(hash_string):
12     if not hash_string:
13         return None
14     decoded = hashids.decode(hash_string)
15
16     if decoded:
17         return decoded[0]
18     return None
```

Access control decorator

系統在 `administration` 與 `front_web` 實作了 `@staff_access_control` 與 `@student_access_control`, 並在使用者未登入或停權時主動阻斷、清空 Session

```
29 def student_access_control(require_email_verification=True):
30     def decorator(view_func):
31         @wraps(view_func)
32         def _wrapped_view(request, *args, **kwargs):
33
34             #Check if login
35             if not request.session.get('student_id'):
36                 messages.error(request, "請先登入帳號")
37                 return redirect("front_web:student_login")
38
39             try:#Check if student exist
40                 obj_student = Student.objects.get(id=request.session.get('student_id'))
41             except Student.DoesNotExist:
42                 messages.error(request, "帳號不存在, 請聯絡中心")
43                 return redirect("front_web:student_login")
44
45             #Check if student active
46             if not obj_student.is_active:
47                 clear_login_session(request)
48                 messages.error(request, "帳號已被停權, 請聯絡中心")
49                 return redirect("front_web:student_login")
50
51             #Check if email verified
52             if require_email_verification and not obj_student.is_email_verified:
53                 messages.warning(request, "您的電子郵件尚未驗證, 請先完成驗證。")
54                 return redirect("front_web:student_register_pending")
55
56             #For view's function to use
57             request.obj_student = obj_student
58             return view_func(request, *args, **kwargs)
59         return _wrapped_view
60     return decorator
61 # endregion
```

異動紀錄 (Base Audit Fields)

強制系統中所有的資料(學生、課程、員工等)都必須記錄「是誰在什麼時間建立或修改的」, 確保資料具備完整的追溯性

```
1  from django.db import models
2
3  # Create your models here.
4  class AuditBaseModel(models.Model):
5      file_status = models.CharField(max_length=100, blank=True, verbose_name="檔案狀態")
6      created_by = models.CharField(max_length=100, blank=True, verbose_name="建立者")
7      created_datetime = models.DateTimeField(auto_now_add=True, verbose_name="建立日期時間")
8      last_updated_by = models.CharField(max_length=100, blank=True, verbose_name="最後更新者")
9      last_updated_datetime = models.DateTimeField(auto_now=True, verbose_name="最後更新日期時間")
10
11     class Meta:
12         abstract = True
13
14     def save(self, *args, **kwargs):
15         if not self.pk:
16             self.file_status = 'created'
17
18         elif self.file_status not in ('deleted',):
19             self.file_status = 'updated'
20         super().save(*args, **kwargs)
21
```